Rollups Node v2.0.0-alpha.12

Internal security review

Report date	August 4, 2026
Remediation status as of	October 28, 2026
Reviewed by	Cartesi QA team
Type	Internal review. This is not an audit by an external firm.

1. Scope

The review covered the following components and versions.

Component	Version
rollups-node	v2.0.0-alpha.12
rollups-contracts	v3.0.0-alpha.6
Machine guest tools and libcmt	v0.17.2
Cartesi Machine emulator	v0.20.0
@cartesi/cli	alpha.34 and alpha.35

The review assumed this deployment model: a single-operator Authority consensus, a third-party HTTPS RPC provider, and an application that moves assets (Ether and tokens) through the portals. Dave and PRT (fraud proofs) were out of scope.

2. Method

- Source review of the node services (advancer, claimer, evm-reader, validator and JSON-RPC API), the CLI and the contracts.
- A validation test catalog executed against a local devnet and public testnets (Base Sepolia and OP Sepolia), covering the CLI, inputs, egress, configuration, state persistence and services.
- Targeted proofs of concept for each suspected issue, run against the real components.

3. Summary of fixed findings

ID	Severity	Component	Finding	Fixed in
ALPHA12-01	High	rollups-node (evm-reader)	Multiple inputs in one transaction stall the application	v2.0.0-alpha.13
ALPHA12-02	Low	rollups-node (CLI)	CLI hardcodes a 30,000,000 gas limit	v2.0.0-alpha.13

4. Fixed findings

ALPHA12-01. Multiple inputs in one transaction stall the application (High)

Component: rollups-node, evm-reader and repository.
Description. Two or more `InputBox.addInput` calls in the same transaction were stored with the same `transaction_reference` (the transaction hash). This violated the `input_application_id_tx_reference_unique` constraint, so the evm-reader rolled back and retried the same block indefinitely.
Impact. After such a transaction was included on chain, the affected application stopped indexing new inputs and could not recover without manual intervention. Any contract or user able to add several inputs in one transaction (for example a batcher or aggregator) could trigger it, so the condition was reachable without special permissions.
Fix. Inputs are now identified by transaction hash and log index, the JSON-RPC API can filter inputs by transaction hash, and integration tests cover multi-input transactions. See rollups-node#789, released in v2.0.0-alpha.13.

ALPHA12-02. CLI hardcodes a 30,000,000 gas limit (Low)

Component: rollups-node, `cartesi-rollups-cli` and the `ethutil` package.
Description. Every transaction sent by the CLI (`send`, `execute`) was created with a fixed gas limit of 30,000,000, which disables gas estimation. Networks that cap gas per transaction below this value, such as Base Sepolia and OP Sepolia, rejected the transaction before it reached a block with *exceeds max transaction gas limit*.
Impact. The operator CLI could not send inputs or execute vouchers on those networks. This affects availability of the tooling, not the safety of funds.
Fix. The CLI now estimates the gas limit by default (commit 5de0ee58, released in v2.0.0-alpha.13). Tracked in rollups-node#786.

5. Reviewed and closed without a code change

Topic	Component	Conclusion
Zero address as guardian or builder of an application	rollups-contracts	Intended behavior. An application without an emergency-withdrawal guardian is a choice of the developer.
Deposits of tokens that do not follow the ERC-20 standard, such as USDT	rollups-contracts	Intended behavior. The portals support standard-compliant tokens only.

6. Developer experience observations

The validation run also produced usability observations that were passed to the maintainers:

- `cartesi build` prints a JavaScript stack trace together with the error when a dependency is missing.
- The JSON-RPC API answers malformed JSON with a plain-text HTTP 400 body instead of a JSON-RPC error object with code -32700.
- `-32602` errors carry a generic message and no data about the offending parameter.
- An invalid database connection string fails after about 15 seconds with a generic timeout error that does not name the host.

7. Findings still under remediation

Other findings from this review were reported to the maintainers and are being addressed. They are not described in this document until a fix is released. This report will be reissued with each one when its fix is available.

8. Reporting a vulnerability

Do not open a public issue for a security problem. Follow the SECURITY.md file in the affected repository. Rewards are covered by the Cartesi Bug Bounty program.